

In one line: A **trapdoor**: cheap one way, infeasible back without a secret. **RSA**: **factoring** $n = pq$. **DH**: the **discrete log** of $g^a \bmod p$. **ECC**: k from kG ; only *generic* $\sqrt{n}$ attacks are known, so a 256-bit curve matches 3072-bit RSA. Shor's algorithm breaks all three.

RSA with toy numbers

$p = 61$, $q = 53$
 $n = pq = 3233$
 $\lambda = \text{lcm}(60, 52) = 780$
 $e \cdot d \equiv 1 \bmod \lambda$
 $e = 17$, $d = 413$
public key (n, e) , private key d (+ p, q)
 $17 \cdot 413 = 7021 = 9 \cdot 780 + 1 \checkmark$
($\varphi = 3120$ instead gives $d = 2753$: also works)
 $m = 65$, $c = m^e \bmod n = 2790$, $m = c^d \bmod n = 65$
 $m \cdot e \cdot d \equiv m$: Fermat mod p and mod q , joined by the CRT
5 products, not 16

Diffie–Hellman ($p = 23, g = 5$)

Alice secret $a = 6$, Bob secret $b = 15$
 $A = 5^6 \bmod 23 = 8$, $B = 5^{15} \bmod 23 = 19$
 $A^B = 8^{15} \bmod 23 = 2$, $B^A = 19^8 \bmod 23 = 2$
both get $g^{ab} = 5^{90} \bmod 23 = 2$; an eavesdropper sees p, g, A, B and must solve $5^x \equiv 8 \bmod 23$, the **discrete log**. $23 = 2 \cdot 11 + 1$ is a safe prime; 5 has order 22, so it generates the whole group
unauthenticated $\Rightarrow$ a MITM runs two DHs

EC point addition (over $\mathbb{R}$)

$y^2 = x^3 - x + 1$
 $P = (-1, 1)$, $Q = (0, 1)$, $R = P + Q = (1, -1)$
chord through P, Q meets the curve a third time; reflect. $P = Q$: the tangent. Identity: the point at infinity O .

RSA — keys and operations

- Keygen**: equal-size primes p, q (1536 bits each for RSA-3072); $n = pq$; $\lambda = \text{lcm}(p-1, q-1)$ (RFC 8017; φ also works, larger d); $e = 65537 = 2^{16} + 1$; $d = e^{-1} \bmod \lambda$ by extended Euclid.
- FIPS 186-5**: $n \geq 2048$; e odd, $2^{16} < e < 2^{256}$ ($e = 3$ is out); $|p - q| > 2^{n \text{ len}/2 - 100}$ (else Fermat's method factors n); $2^{n \text{ len}/2} < d < \lambda$.
- Encrypt** $c = m^e$, **decrypt** $m = c^d$; **sign** $s = \text{EM}^d$, **verify** $s^e = \text{EM}$ (all mod n ; EM = padded $H(m)$). $e = 65537$: 16 squarings + 1 product.
- CRT** (RFC 8017 key $p, q, dP, dQ, qInv$): two half-size powers, $\approx 4 \times$ faster. Toy: $dP = 53, dQ = 49, qInv = 38; m_1 = 45^{53} \bmod 61 = 4, m_2 = 34^{49} \bmod 53 = 12, h = (m_1 - m_2) qInv \bmod p = 1, m = m_2 + qh = 65$.
- Factoring gives d ; "breaking RSA $\Rightarrow$ factoring" is unproven.

Padding — textbook RSA is broken

deterministic	same $m \rightarrow$ same c : guess, encrypt, compare
malleable	$c \cdot 2^e \bmod n$ decrypts to $2m$
$e = 3, m^3 < n$	c is a plain cube: take the integer cube root
v1.5 encryption	a 1-bit "padding OK?" oracle decrypts or signs in $\sim 2^{20}$ queries (Bleichenbacher); ROBOT: 27 of the top 100 domains; Marvin: timing alone

Fix: **OAEP** (encryption) and **PSS** (signatures), REQUIRED for new applications by RFC 8017. NIST disallowed v1.5 key transport after 2023; v1.5 *signatures* survive in certificates and JWT RS256. OAEP carries $\leq k - 2h_{\text{Len}} - 2$ bytes: RSA-2048 + SHA-256 = **190 B** $\rightarrow$ wrap a key (hybrid), never bulk data.

Factoring cost — sub-exponential

$\text{GNFS} \approx \exp(1.923 (\ln n)^{1/3} (\ln \ln n)^{2/3}) \rightarrow 3072$ bits for 128-bit security. Records: RSA-250 (829 bits, ~ 2700 core-years); RSA-260 (862 bits, Sep 2026, ~ 4900 GPU-days $\approx \$400k$, "essentially no algorithmic advancements"; RSA-1024 put at $\sim \$30M$, RSA-2048 $\sim 10^9 \times$ harder).

Diffie–Hellman and the discrete log

- Each side sends $g^x \bmod p$; both reach g^{ab} ; unauthenticated, so sign the transcript. The NFS solves the **DLP** in $\mathbb{Z}_p^*$ sub-exponentially too $\rightarrow$ RSA-like sizes (3072-bit p , 256-bit subgroup).
- RFC 7919 safe-prime groups ffdhe2048...8192, $g = 2$ (2048 rated ≈ 103 bits); peers MUST check $1 < Y < p - 1$, else $Y = p - 1$ forces a 2-element subgroup.
- Logjam**: NFS precomputation depends only on p . 512-bit export DH fell per connection (8.4 % of top-1M domains); breaking the commonest 1024-bit prime would expose 18 % of top-1M HTTPS.

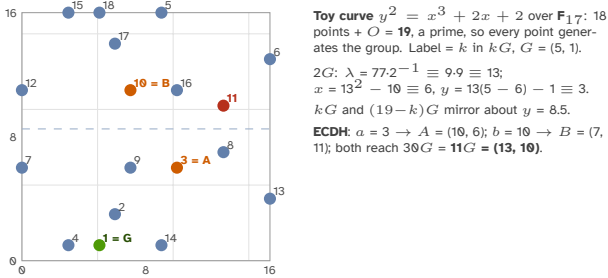
Comparable strength — SP 800-57 Pt 1 Rev 5, Table 2

bits	symmetric	RSA/DH	ECC (ln)	ratio	NIST (IR 8547 draft)
≤ 80	2TDEA	1024	160–223	—	insufficient
112	3TDEA	2048	224–255	9 $\times$	deprecated after 2030
128	AES-128	3072	256–383	12 $\times$	disallowed after 2035
192	AES-192	7680	384–511	20 $\times$	disallowed after 2035
256	AES-256	15360	512+	30 $\times$	disallowed after 2035

IR 8547 treats RSA, ECDSA, EdDSA, DH, ECDH alike: Shor solves factoring and both discrete logs in polynomial time; Gidney 2025: RSA-2048 in < 1 week on $< 1M$ noisy qubits.

Elliptic curves — the group

Points on $y^2 = x^3 + ax + b$ over $\mathbb{F}_p$, plus O . Chord $\lambda = \frac{y_2 - y_1}{x_2 - x_1}$, tangent $\lambda = \frac{3x_1^2 + a}{2y_1}$; $x_3 = \lambda^2 - x_1 - x_2$, $y_3 = \lambda(x_1 - x_3) - y_1$; $-P = (x, -y)$; divide = multiply by the inverse mod p . kG by **double-and-add**. **ECDLP** (k from kG): best known for good curves is Pollard's rho, $\sim \sqrt{n}$ steps $\rightarrow$ 256-bit $n = 128$ -bit security. Hasse: $\#E \in p + 1 \pm 2\sqrt{p}$; cofactor $h = \#E/n$.



Curves in use

curve	equation · field	h	used for
P-256	$y^2 = x^3 - 3x + b$, $p = 2^{256} - 2^{224} + 2^{192} + 2^{96} - 1$; b from a seed	1	TLS 1.3 MUST; ES256, APNs
secp256k1	$y^2 = x^3 + 7$, $p = 2^{256} - 2^{32} - 977$	1	Bitcoin
Curve25519	$v^2 = u^3 + 486662u^2 + u$, $p = 2^{255} - 19$, $u = 9$; clamp: low 3 bits 0, bit 255 = 0, bit 254 = 1	8	X25519 (TLS SHOULD)
Ed25519	$-x^2 + y^2 = 1 + dx^2y^2$, $d = -\frac{121665}{121666}$ same curve, Edwards form	8	SSH default

ECDSA vs Ed25519 — the nonce

	ECDSA (FIPS 186-5)	Ed25519 (RFC 8032)
nonce	random k , or RFC 6979 (deterministic)	$r = \text{SHA-512}(\text{prefix} \parallel M) \bmod L$
sign	$r = (kG)_x$, $s = k^{-1}(z + r d) \bmod n$	$R = rB$, $S = r + H(R \parallel A \parallel M) \bmod L$
bytes	$r \parallel s = 64$ (JWS), DER ≤ 72	64; reject $S \geq L$
malleable	yes: $(r, n - s)$ verifies	no

Nonce reuse: same $k \Rightarrow$ same r ; $k = \frac{z_1 - z_2}{s_1 - s_2}$, $d = \frac{s_1 k - z_1}{r} \bmod n$: the key from two signatures. Sony signed PS3 code with one fixed k ; LadderLeak took OpenSSL ECDSA keys from < 1 bit of nonce leak per signature.

Traps

- ! "Signing = encrypting with the private key" — only in textbook RSA.
- ! "256-bit ECC = 256-bit security" — it is 128.
- ! A starved RNG at key generation repeats a prime: $\text{gcd}(n_1, n_2) = p$ ($\text{gcd}(3233, 61 \cdot 59) = 61$). A batch GCD factored the RSA keys of 0.50 % of TLS and 0.03 % of SSH hosts.
- ! Square-and-multiply branches on secret bits; timing leaks the key (Kocher) $\rightarrow$ constant-time ladder, blinding.
- ! ECDH without an on-curve check: invalid points leaked keys from 2 of 8 TLS libraries. X25519 accepts any 32 bytes by design.

